

SRE Agent

A secure, environment-agnostic automation platform for our infrastructure

Audience: Leadership & CTO · **Status:** built, tested, in review for production

The problem we set out to solve

- Infrastructure ops (Proxmox + Hetzner) are **manual, repetitive, and risky** — one wrong command can take down a production VM.
- We want **automation** to hit a **99.99% uptime objective**, but unsupervised automation on production is itself a risk.
- Credentials and approvals were **ad-hoc** — hard to rotate, easy to misuse.

The tension: move faster *and* reduce the chance of a costly mistake.

What we built

An **environment-agnostic coordinator** that automates infrastructure work with a **human-in-the-loop** and a **safety-first** design.

- **Monitors** nodes, VMs, and services continuously.
- **Detects drift** (what *should* exist vs. what *does*).
- **Executes** routine ops automatically; **gates risky ones** behind human approval.
- **Extensible**: new platforms, workflows, and integrations plug in without touching the core.

The core idea that makes it safe

Every action is classified, gated, and audited by deterministic code. The AI never sits on the safety path.

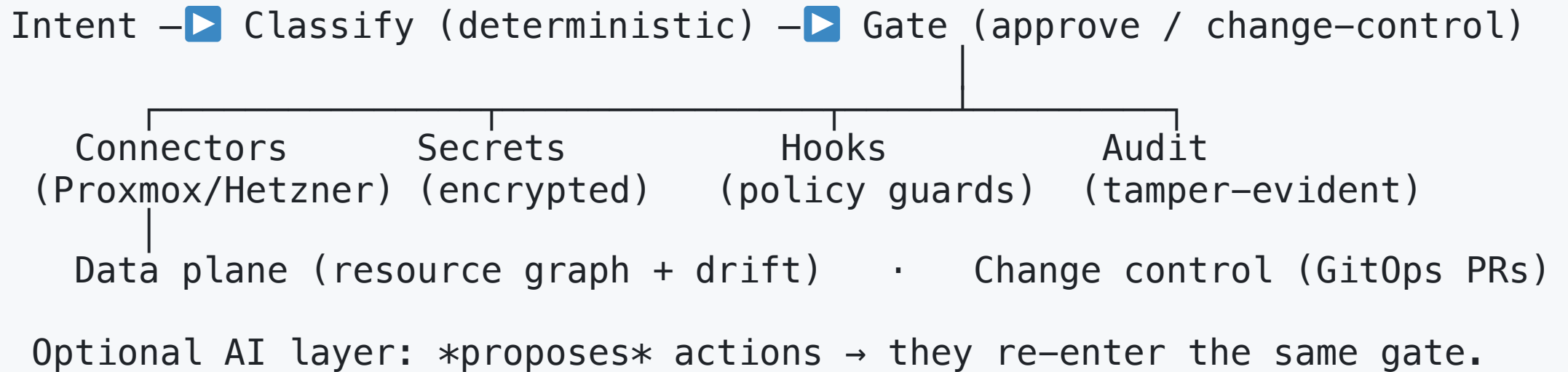
Autonomy tiers decide what happens automatically vs. what needs a human:

Tier	Example	Behavior
Auto	list/health/status	runs immediately
Notify	start a VM	runs + notifies
Approve	delete a VM	blocked until a human approves
PR-only	high-blast-radius change	proposed as a reviewed change request

Security posture (for the CTO)

- **Human-in-the-loop is real, not decorative** — approvals are **authenticated** (allow-listed approvers, separation of duties) and **provenance-checked**; you can't self-approve.
- **Fail-closed everywhere** — if anything is uncertain (unknown op, channel down, expired window), the action is **denied**.
- **Secrets**: encrypted-at-rest store (AES-256-GCM), short-lived just-in-time delivery, never logged; centrally rotated via Bitwarden so one rotation updates every operator.
- **Hardened transport** — TLS verification fails closed; HTTPS-only; no credential leakage.
- **Full audit trail** of every decision and action.
- **Independently reviewed** (security + architecture); ship-blockers found and fixed.

Architecture at a glance



Pluggable **connectors / skills / hooks**; the AI is an **optional proposer**, never an executor.

What we delivered

- **Full platform** built in 3 phases + cleanup + security hardening.
- **211 automated tests** passing; security paths explicitly tested.
- **One-command container** — operators run it with zero install; no secrets baked in.
- **Operator docs**: junior-support runbook, container guide, secrets runbook, architecture spec.
- **Validated live** against our real infrastructure (Proxmox node + VMs + GitLab healthy).
- Shipped through **peer-reviewed merge requests** (platform merged; security hardening in review).

How the team operates it

- **Run from a container** — `sre-agent monitor`, `status`, `batch approve`, ...
- **Junior support** can safely run read-only checks and queue actions; **seniors approve**.
- **Secrets**: stored once in Bitwarden; each engineer authenticates as themselves; rotation is one edit and everyone picks it up — no stale credentials.
- **99.99% objective** pursued via continuous monitoring + drift detection + *safe* remediation (proposed, reviewed, applied).

Cost & footprint

- **Near-zero added cost:** Python standard library + one vetted crypto dependency.
- **Secrets:** uses existing **Bitwarden Teams (\$36/yr)** — no paid Secrets Manager add-on needed.
- **Runs on existing hardware** (local Docker / our Proxmox VMs); no new SaaS.
- **Low maintenance:** modular, heavily tested, documented for the on-call team.

Honest risk assessment

Production-ready now: the safety model (classification, authenticated approvals, fail-closed gates), encrypted secrets, hardened transport, audited actions.

Before we trust it with autonomous production changes, we will add:

- **CI/CD gate** (automated tests + lint + secret scanning on every change).
- **Value-level secret scrubbing** and a few defense-in-depth hardening items.
- A controlled rollout: **read-only first → approved actions → broader automation.**

Roadmap

Horizon	Focus
Now	Land security hardening MR; stand up CI gate
Next	Data-plane drift → GitOps remediation; expand monitored services
Later	AI proposer for routine remediation (still human-gated); durable long-running workflows; more connectors

The ask

1. **Endorse** moving the SRE Agent toward a **supervised production pilot** (read-only + approved actions first).
2. **Approve** the small remaining investment: CI pipeline + a security follow-up pass.
3. **Confirm** the operating model: on-call engineers as authorized approvers; Bitwarden as the secrets source of truth.

Outcome: safer, faster infrastructure operations on a path to 99.99% — with humans in control and a full audit trail.

Appendix / Q&A

- **"Can the AI delete a VM on its own?"** No — destructive ops are blocked until an authorized human approves; the AI can only *propose*.
- **"What if a laptop is stolen?"** No long-lived secrets on laptops; creds are fetched at run time and short-lived.
- **"How do we know it works?"** 211 automated tests, an independent security review, and live validation against our infra.
- **"What does it cost?"** Effectively nothing new — existing tooling and hardware.